

INCIDENT BRIEFING — WEEK 4

Phishing-Enabled Account Compromise via Proxy Kit

Adversary-in-the-Middle (AiTM) Credential Theft & Multi-Factor Authentication Bypass

INCIDENT ID

PHI-2026-0417

SEVERITY LEVEL

⚠ High

INCIDENT FRAMEWORKS

SANS / NIST SP 800-61r3

PREPARED FOR

Executive Leadership

Executive Incident Overview

Executive Summary

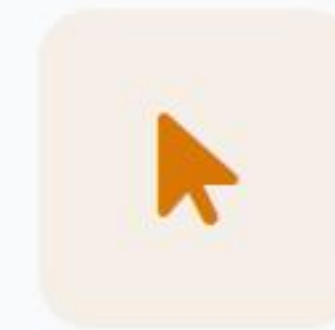
On 15 June 2026, an adversary-in-the-middle (AiTM) phishing campaign targeted the Finance department. By mimicking an internal IT Helpdesk password warning, the attacker bypassed multi-factor authentication (MFA) on a single analyst account.

Thanks to robust dual-authorization controls in the Finance workflows, a fraudulent payment attempt was successfully blocked. Total containment was achieved in under 4 hours, resulting in zero dollar loss.



85

Emails
Delivered



14

Links
Clicked



3

Credentials
Entered



1

Compromised



<4h

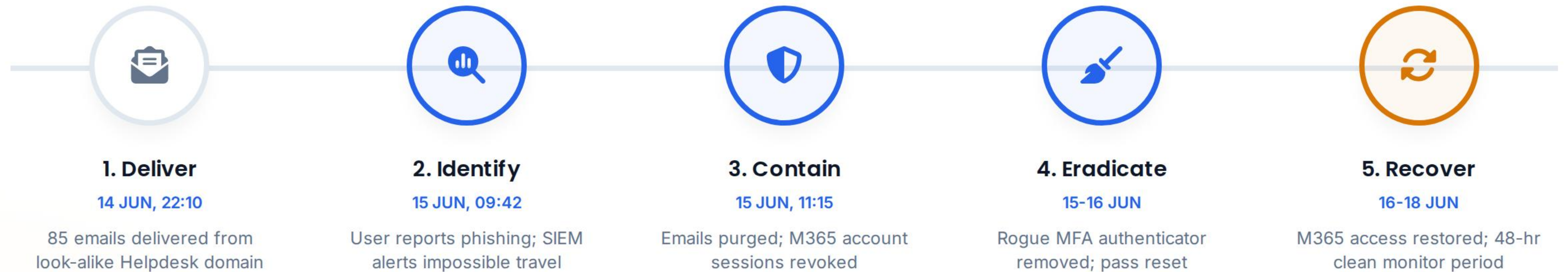
Containment
Time



\$0

Funds Lost

| Incident Lifecycle Timeline



| How the AiTM Attack Worked

STEP 01

Delivery

A look-alike domain sends a fake password-expiry notification to targets.

STEP 02

Redirection

Links pass through open redirectors to delay signature detection.

STEP 03

Proxy Relay

AiTM phishing kit mirrors live M365 authentication flows to the user.

STEP 04

MFA Bypass

Attacker captures the validated post-MFA session cookie in real time.

STEP 05

Persistence

Attacker registers a new MFA authenticator device to secure backup access.

STEP 06

Blocked Fraud

Attacker attempts billing routing change; blocked by dual-approval policy.

| Detailed Impact Assessment

⚠️ What Was Affected

- **Single Identity Compromised:** A single Finance Analyst active directory identity and inbox were accessed by the attacker.
- **Endpoints Unaffected:** Zero on-premises servers, virtual machines, or local workstation endpoints were compromised.
- **Data Integrity Intact:** Incident forensics found no evidence of email exfiltration, bulk downloads, or rogue forwarding rules.
- **Precautionary Resets:** Two additional accounts had exposed credentials and were proactively reset before access occurred.

✅ What Was Prevented

- **Fraudulent Wire Transfer Blocked:** Attacker attempted to alter external payment details; blocked by internal dual-approval control.
- **Zero Financial Loss:** No corporate or customer funds were transferred or lost during this campaign.
- **Zero Business Downtime:** Business services and operations suffered no disruption or system offline states.
- **Minimal Labor Resource Cost:** Total response effort was capped at ~6 analyst-hours and ~2 IT Support-hours.

| Containment & Remediation



SANS Containment Actions

Purged the phishing email across all 85 target mailboxes. Blocklisted malicious landing domains and redirector hosts. Disabled compromised account and revoked active tokens.



SANS Eradication Actions

Identified and removed the attacker's rogue MFA authenticator app. Reset directory passwords for all 3 users with credential exposure. Audited and verified inbox routing rules.



SANS Recovery & Monitoring Phases

Restored employee mailboxes and identities with freshly enforced complex credentials. Conducted safe MFA device registration under secure network guidelines. Enhanced directory monitoring logs and workstation EDR agents for 48 hours to confirm zero residual attacker command execution.

Core Incident Findings



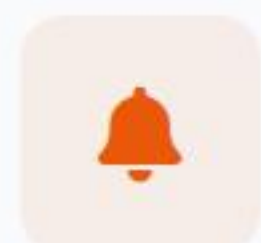
Incident Escalation Policy Worked

SOC escalation criteria and communication matrices functioned perfectly. L1-L3 analysts and IT personnel coordinated seamlessly, containing the attack vector within four hours of user reporting.



Legacy MFA is Insufficient

The AiTM reverse-proxy bypasses traditional push/OTP MFA seamlessly by hijacking authenticated HTTP session cookies. Standard MFA must be hardened for high-risk corporate roles.



Identified MFA Registration Gap

There was an operational detection gap: our SIEM did not instantly alert on a new MFA device registration occurring immediately after a successful login from an anomalous subnet.



Business Controls Saved the Asset

While technical security controls failed initially, the Finance department's dual-authorization workflow was the final safety net that stopped external fraudulent payment modification.

Strategic Security Roadmap

Focus Area	Remediation Action Item	CSF Match	Urgency
Email Gateway	Extend gateway URL rewrite rules to actively sandbox open redirectors & shorteners.	DE.CM-09	High (7 Days)
SIEM Alerting	Configure instant SIEM alerts for new MFA registration events within 1 hour of profile login.	DE.AE-06	High (7 Days)
MFA Hardening	Deploy phishing-resistant FIDO2 / WebAuthn physical security keys for all high-risk Finance teams.	PR.AA-03	Medium (30 Days)
User Training	Deliver targeted, scenario-based phishing training highlighting modern proxy-based AiTM attacks.	ID.IM-01	Medium (30 Days)
IR Playbooks	Update incident response playbook templates with passive DNS/CTI domain investigation guidelines.	ID.IM-04	Low (90 Days)



Questions & Answers

The incident is officially resolved, and critical defense-in-depth posture adjustments have been scheduled. The full technical artifact log is accessible in PHI-2026-0417.

Corporate Security Incident Response Team (CSIRT)